

Network Architecture Design Document

Prepared by: Omkar Sawant

Client: GlobalTech Corp

Date: 23 May 2026

Project: Implementing a Secure Network Architecture for a Large Enterprise

Organisation: Spinnaker Analytics

1. Executive Summary

- This document presents the proposed secure network architecture for GlobalTech Corp, a multinational corporation with a primary headquarters in Mumbai, two remote offices, and approximately 300 remote employees.
- The design is based on findings identified in the Network Architecture Assessment Report (22 May 2026), which identified 15 security gaps across five domains.
- The proposed architecture addresses all identified vulnerabilities through a layered security model incorporating next-generation perimeter controls, network segmentation, Zero Trust remote access, strong identity management, data encryption, and centralized monitoring.
- The design is intended to be scalable across all current and future sites.

2. Current State Assessment Reference

The current state assessment was conducted separately and documented in the Network Architecture Assessment Report (22 May 2026). Key findings that directly inform this design include:

- Flat network with no VLAN segmentation — enables lateral movement across all departments
- Legacy stateful firewall with no application-layer inspection
- No IDPS deployed — intrusion attempts go undetected
- VPN using deprecated IKEv1/PPTP protocols vulnerable to credential interception
- No multi-factor authentication enforced for any user account
- No centralised logging or SIEM — no visibility into security events
- Internal services transmitting data over unencrypted HTTP

Each of these findings is directly addressed in the proposed architecture below.

3. Proposed Network Architecture

3.1 Design Principles

The proposed architecture is built on the following core principles:

- **Defence in depth:** multiple independent security layers so that failure of any single control does not compromise the entire network
- **Least privilege:** users, systems, and network segments are granted only the minimum access required for their function
- **Zero Trust:** no implicit trust based on network location — every access request is authenticated, authorised, and verified
- **Encryption everywhere:** all data encrypted in transit (TLS 1.3) and at rest (AES-256)
- **Centralised visibility:** all sites and devices feed logs into a single SIEM platform at HQ

3.2 HQ Architecture — Mumbai Primary Site

- The HQ at Mumbai serves as the primary site and houses all centralised security infrastructure.
- Traffic flows through the following layers from the internet inward:

Layer 1: Perimeter — NGFW + IDPS

- All inbound and outbound internet traffic passes through a next-generation firewall (NGFW) with an inline intrusion detection and prevention system (IDPS).
- The NGFW performs application-layer inspection, SSL/TLS decryption, and allowlist-based egress filtering.
- The IDPS maintains updated signature feeds and triggers alerts on anomalous traffic patterns.
- **Recommended solutions: Palo Alto Networks PA-Series, Fortinet FortiGate**
- **IDPS: Snort, Suricata, or integrated NGFW threat prevention module**

Layer 2: DMZ

- A demilitarised zone (DMZ) sits between the perimeter and the internal network. It hosts services that must be reachable from the internet without exposing internal resources:
 - **Web proxy: all outbound web traffic is routed through the proxy for inspection and logging**
 - **Reverse proxy: handles inbound HTTP/HTTPS requests and forwards to internal application servers**
 - **Email gateway: filters inbound and outbound email for spam, phishing, and malware**

Layer 3: Core L3 Switch and VLAN Segmentation

- The internal network is segmented into discrete VLANs using a core Layer 3 switch. Inter-VLAN routing is strictly controlled by access control lists (ACLs) applying least-privilege traffic policies. The following VLANs are defined:
 - **User VLAN:** general employee workstations with EDR enforced via NAC before network access is granted
 - **Server VLAN:** application servers, database servers, and file servers — AES-256 encryption at rest, TLS 1.3 for all service-to-service communication
 - **Finance / HR VLAN:** restricted access segment — RBAC enforced, accessible only to authorised roles
 - **DMZ VLAN:** isolated from all internal VLANs, internet-facing services only
 - **Guest VLAN:** internet-only access, no routing path to any internal segment
 - **IoT VLAN:** isolated segment for IoT and physical security devices

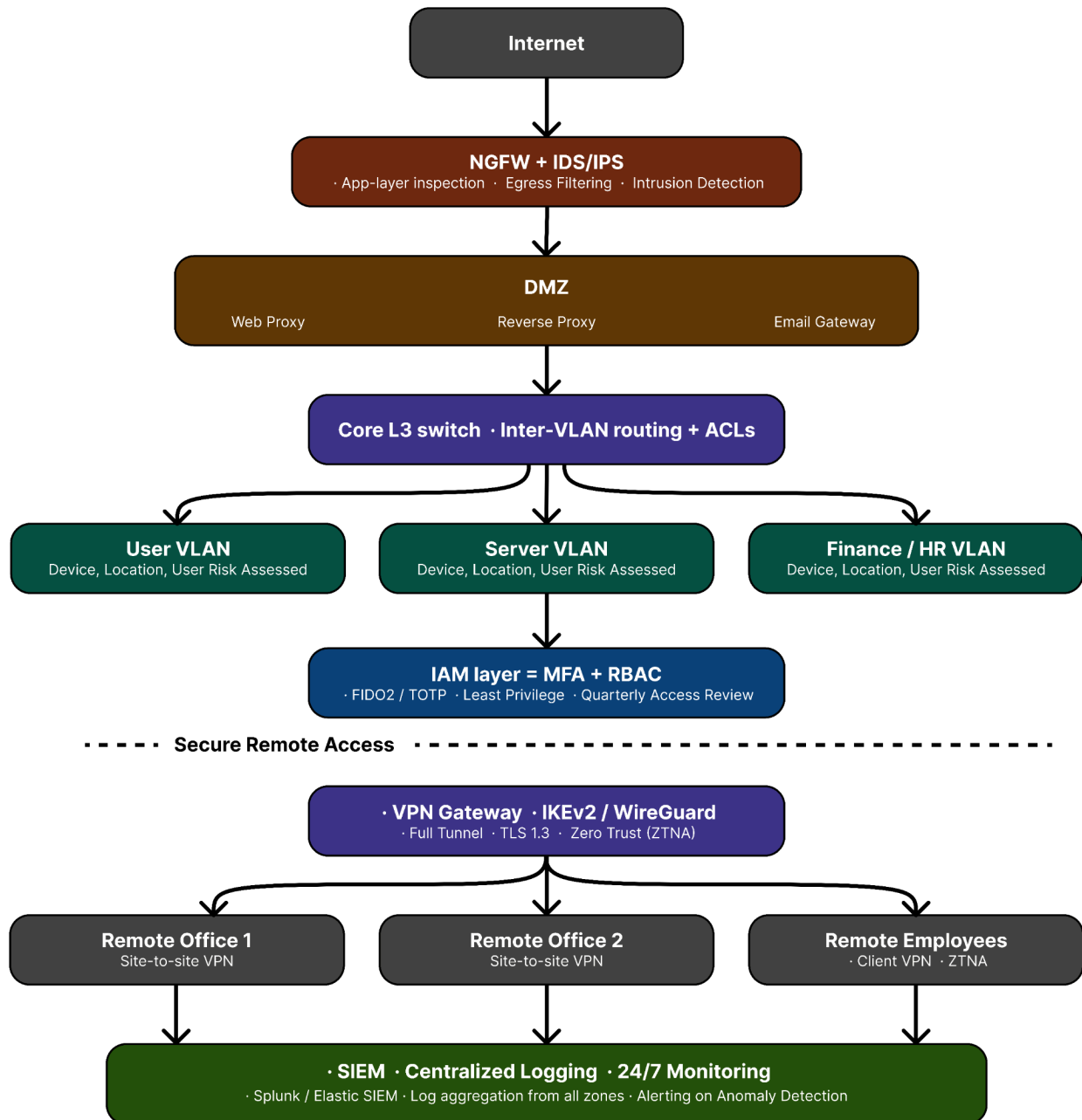
Layer 4: Identity and Access Management (IAM)

All access to internal resources requires authentication through the IAM layer:

- Multi-factor authentication (MFA) is mandatory for all user accounts: TOTP authenticator apps as minimum; FIDO2 hardware security keys required for all privileged and administrator accounts
- Role-based access control (RBAC) defines permissions for each user role with quarterly access reviews
- Principle of least privilege applied — users access only what their role requires

Layer 5: SIEM and Centralised Logging

- A SIEM platform aggregates security logs from all network zones and all remote sites. Correlation rules trigger alerts on suspicious activity patterns. The SIEM serves as the single source of truth for security event investigation across the entire organisation.
 - **Recommended platforms: Splunk, Elastic SIEM, or Microsoft Sentinel**
 - **Log sources: NGFW, IDPS, switches, endpoints, identity provider, VPN gateway, application servers**



3.3 Multi-Site Network Topology

- GlobalTech Corp operates across three locations connected to the HQ via encrypted VPN tunnels.
- All remote sites and employees are treated as untrusted networks until authenticated; consistent with the Zero Trust model.

HQ — Mumbai (Primary Site)

- Houses all centralised security infrastructure as described in Section 3.2.
- Acts as the VPN hub for all remote connections.
- All remote site logs are forwarded to the SIEM at HQ.

Remote Office 1 — Delhi

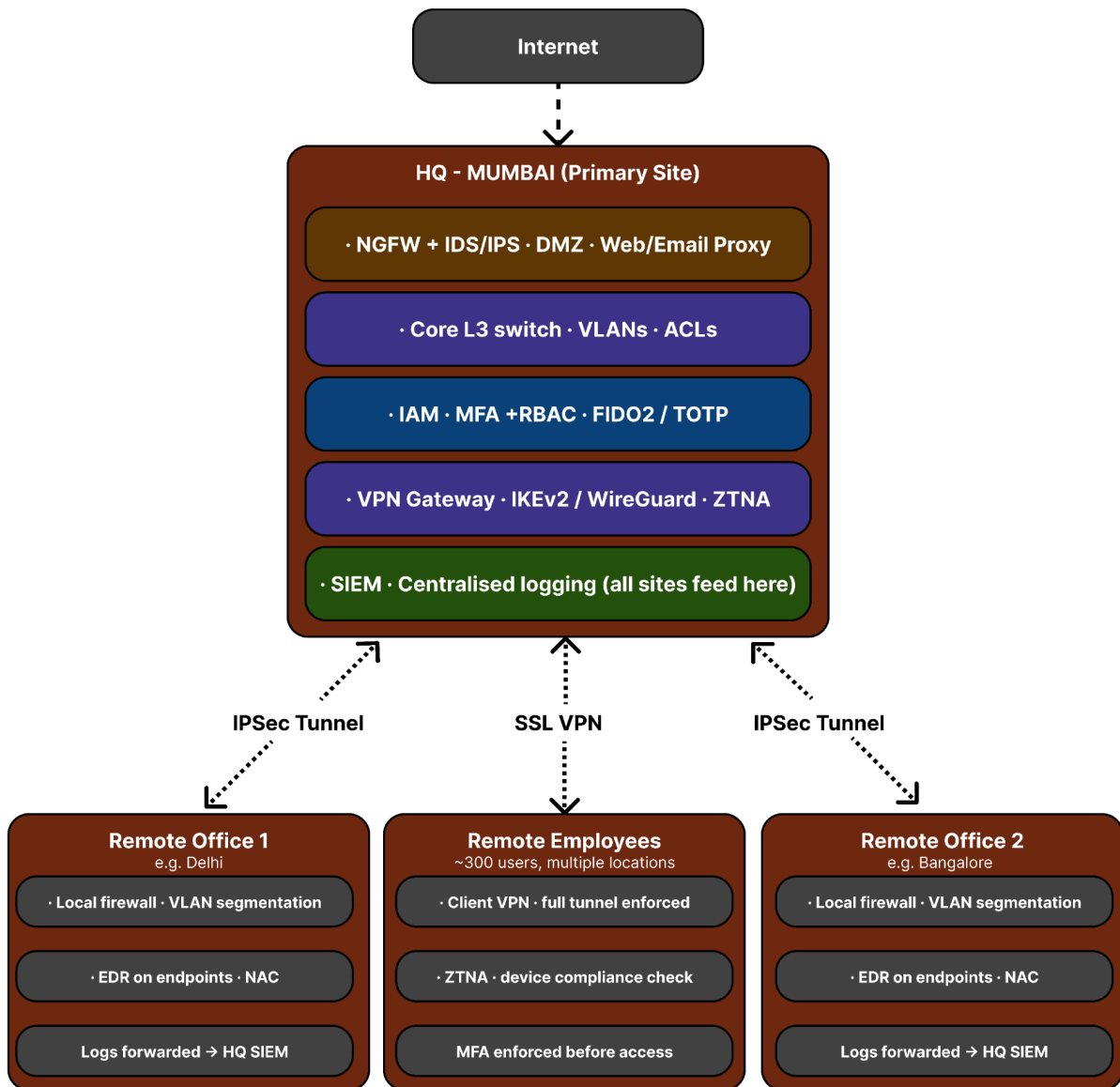
- Connected to HQ via a site-to-site IPSec VPN tunnel using IKEv2.
- The remote office maintains its own local security controls:
 - Local firewall with VLAN segmentation mirroring the HQ design
 - EDR deployed on all endpoints with NAC compliance enforcement
 - All security logs forwarded to the centralised SIEM at HQ

Remote Office 2 — Bangalore

- Identical configuration to Remote Office 1.
- Connected to HQ via a dedicated site-to-site IPSec VPN tunnel.
- Local security controls and log forwarding to HQ SIEM are enforced.

Remote Employees (~300 users)

- Remote employees connect via SSL VPN (client VPN) with full tunnel enforced; all traffic routes through the corporate network for inspection.
- Zero Trust Network Access (ZTNA) controls are applied:
 - Device compliance is checked before access is granted.
 - MFA is enforced at every login.
 - Per-session, per-resource access is granted based on user identity, device posture, and context; not blanket network access.
 - Recommended ZTNA solutions: Cloudflare Access or Zscaler Private Access.



..... Encrypted VPN tunnel (bidirectional) - - - - - Internet

4. Security Controls Summary

Finding	Architectural Control
Finding 1 — Legacy firewall	Replaced by NGFW with application-layer inspection, SSL/TLS decryption, and threat intelligence integration
Finding 2 — Permissive egress rules	Allowlist-based egress filtering on NGFW; all outbound traffic routed through web proxy
Finding 3 — No IDPS	Inline IDPS deployed at perimeter with updated signature feeds and high-confidence alerting
Finding 4 — Flat network	VLAN segmentation across 6 functional segments (User, Server, Finance/HR, DMZ, Guest, IoT)
Finding 5 — No ACLs	ACLs enforced on all inter-VLAN routing interfaces applying least-privilege traffic policies
Finding 6 — Guest Wi-Fi on corporate subnet	Guest VLAN isolated with internet-only access; no routing path to any internal segment
Finding 7 — Deprecated VPN protocols	IKEv2/IPSec and WireGuard replacing IKEv1/PPTP; TLS 1.3 enforced on SSL VPN
Finding 8 — Split tunnelling	Full tunnel VPN enforced for all remote connections; all traffic inspected via corporate network
Finding 9 — No Zero Trust	ZTNA implemented; per-session, per-resource access based on identity, device posture, and context
Finding 10 — No MFA	MFA mandatory for all users (TOTP minimum); FIDO2 hardware keys required for all admins
Finding 11 — No EDR	EDR deployed on all endpoints with behavioural detection, process monitoring, and automated response
Finding 12 — Excessive privileges	RBAC formalised with defined roles, least-privilege enforcement, and quarterly access reviews
Finding 13 — HTTP on internal services	TLS 1.3 enforced on all internal services; internal CA deployed for service-to-service certificates
Finding 14 — No centralised logging	SIEM deployed aggregating logs from all zones and all remote sites with correlation alerting
Finding 15 — No encryption at rest	AES-256 encryption at rest on all file and database servers; key management via HashiCorp Vault

5. Conclusion

- The proposed secure network architecture for GlobalTech Corp addresses all 15 findings identified in the current-state assessment.
- The design adopts a layered defence-in-depth approach, applying Zero Trust principles across all remote access scenarios and enforcing least-privilege controls throughout the network.
- The architecture is designed to scale with the organisation: the VLAN structure, centralised IAM, and SIEM platform can extend to additional sites without redesign.
- Implementation should be prioritised in the order of severity:
 - perimeter controls and MFA first,
 - followed by VLAN segmentation,
 - VPN migration, EDR deployment,
 - and finally logging and encryption.
- Subsequent deliverables will provide detailed configuration guides for each component of this architecture.